



Allied Bank

Information Security Incident Management Procedure

CONFIDENTIAL MATERIAL – FOR BANK’S USE ONLY

This manual and any information annexed with it contains restricted and/or privileged information and is intended only for authorized use of Bank’s employees. None of the materials provided in this manual may be used, reproduced or transmitted, in any form or by any means, electronic or mechanical, including recording or the use of any information storage and retrieval system, without written permission of the Bank.

Presented in RMC through Circulation

Meeting No. 15 Dated: 15/10/2019

Initial FD

RECOMMENDATION & REVIEW

RECOMMENDED FOR APPROVAL

Chief – RMG

APPROVED BY:

RMC

DOCUMENT DESCRIPTION

Title	Information Security Incident Management Procedure
Version No.	2.0
Ownership	Information Security & Governance, RMG
Approving Authority	RMC
Date of Approval	
Document Type	Full scope document review
Governing Policy	Information Security Policy
Date of Implementation	
Review Frequency	Annual
Last Approval Date	March 29, 2016
Next Review Date	
Availability	Share Point Portal

TABLE OF CONTENTS

1. INTRODUCTION & SCOPE	5
1.1 INTRODUCTION	5
1.2 SCOPE	5
2. PROCEDURE DETAILS	6
2.1 PREPAREDNESS	6
2.2 IDENTIFICATION/DETECTION OF INCIDENTS	6
2.2.1 ANALYZING THE INCIDENTS	6
2.2.2 RELEVANT STAKEHOLDERS	7
2.3 CONTAINMENT OF INCIDENT	7
2.4 REMEDIATING INCIDENTS	8
2.5 RECOVERY	8
2.6 FOLLOW-UP / LESSONS LEARNED	8
3. ROLES & RESPONSIBILITIES	10
3.1 USERS – EMPLOYEES	10
3.2 INCIDENT MANAGEMENT TEAM	10
3.3 SECURITY OPERATIONS CENTER	10
3.4 NETWORK / SI-S&DA/ APPLICATION ADMIN/ FRMR TEAMS	10
3.5 DH-SOC	11
3.6 TECHNOLOGY COMPLIANCE DEPARTMENT-CG	11
4. INTERDEPENDENCIES	11
5. PROCESS FLOW	12
6. VERSION HISTORY	15
7. ANNEXURES	16
7.1 ANNEXURE A –INCIDENT REPORT FORM	16
7.2 ANNEXURE B – REPORTING TEMPLATE AS PER PSD CIRCULAR NO. 03 OF 2015 (FOR REPORTING TO SBP)	17
8. GLOSSARY	18
8.1 ACRONYMS	18
8.2 DEFINITIONS	18

1. INTRODUCTION & SCOPE

1.1 INTRODUCTION

In compliance of Information security policy of the Bank, this document describes the Information Security Incident Management process to be followed in case of an Information Security incident. It is vital to avoid/resolve incidents in an organized and systematic manner. The purpose of information Security Incident Management Procedure is to document, analyze an incident and to devise corresponding remedial, prevention plan for effective and efficient management of information security incidents. Following are the incident types:

1.1.1. Control Breach

1.1.2. Data Breach

1.1.3. Financial Loss

Severity of Data breach and Financial Loss is categorized as High while Control Breach shall be categorized as Medium till the time not converted into the other two categories.

1.2 SCOPE

Scope of this procedure entails incidents pertaining to bank's Information, impacting its confidentiality, integrity and availability in terms of information security. Incidents such as floods, fires, power-related disruptions and other natural disasters have not been included in the scope of this document and shall be addressed in ABL's Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP). This procedure is to be followed by all employees of the Bank.

2. PROCEDURE DETAILS

Generally, compromise in any area/s of the security triad i.e. confidentiality, integrity and availability of an "information asset" is termed as an "Information Security Incident". Any event that meets the incident definition must be reported, analyzed, contained, recovered, monitored till closure and remediated to prevent/ minimize the possibility of future occurrences. Detailed requirements and process for each of these steps are given below:

2.1 PREPAREDNESS

The Bank shall take necessary proactive and preemptive measures to avoid occurrence of Information Security incidents. In this regard a comprehensive "Information Security Posture" (Annexure C) has been built and is in place, which provides the preparedness for combating cyber security threats.

2.2 IDENTIFICATION/DETECTION OF INCIDENTS

Any employee, who suspects that one or more security breach events have occurred, should report to their line management to protect the information asset/s and data from further damage or loss, who shall immediately then report these event to the Incident Management Team "IMT" through email @ <imt@abl.com>, comprising of members from Information Security, Information Technology, Fraud Management and Business representatives.

2.2.1 ANALYZING THE INCIDENTS

On receipt of information IMT shall issue a unique number before initiating analysis. Analysis of the incident often provides additional information such as initial infection vector, propagation mechanism(s), and other findings that may prove useful to investigate further or to devise a permanent containment of the incident. On receipt of information regarding any security breach event, IMT team on best possible basis will analyze that event to establish the happening as an incident or not to safeguard bank's interest.

The Incident Management Team will collect all available information (from Network/Systems /Database/Application and SOC teams) pertinent to the incident and to evaluate this, the IMT will consider the following

- a) Identify the affected resources.
- b) Identify the types of information affected e.g. customer/personal/payment card data etc.
- c) Estimate the severity of the incident based on data classification and incident type/severity.
- d) Determine the effects of the threat/attack and identify all possible information, systems, and resources that may have been targeted/compromised.
- e) Determine whether or not forensic collection, preservation, and analysis will be required.

- f) Record and maintain all the information regarding steps taken for establishing the Incident analysis efforts for further reference.

2.2.2 NOTIFYING RELEVANT STAKEHOLDERS

After having sufficient confirmation that an incident has happened, the Incident Management Team will communicate to different internal stakeholders and regulatory/law enforcement bodies accordingly. Communicating to internal stakeholder require GH Information Security & Governance's approval and for regulatory/law enforcement bodies, Chief RMG/ITSC approval must be accorded against the following information according to the relevancy

- a) Justification for the incident severity level
- b) Confidence in current information
- c) Number and type of systems involved
- d) Type of data possibly at risk
- e) Personnel/resources required to continue the investigation

NOTE: The Bank shall report to Banking Policy & Regulation Department (BPRD), SBP within forty-eight (48) hours after the incident all established information/cyber security breaches and related incidents involving financial loss, stealing of confidential data. (Annexure -B)

2.3 CONTAINMENT OF INCIDENT

Containment involves making changes in identified Information technology components to mitigate the incident based on the analyzed information in previous step. Some typical action taken during this phase may be:

- a) modifying the network access rule for affected systems,
- b) reset passwords for affected systems/accounts,
- c) implement firewall/detection control rules to block or monitor certain IPs/systems to block attacks or,
- d) powering down or disconnecting the affected system from the other functioning systems.

In order to determine the containment decisions, the IMT will consider to

- 2.3.1. Consult the key stakeholders, subject matter experts (SMEs)/principal vendors to determine the most effective and efficient initial containment strategy.
- 2.3.2. Advise temporary containment measures to the concerned teams e.g. Network, Systems, Database, Application, SOC and FRMR/Transaction Monitoring.
- 2.3.3. Take feedback from the concerned stakeholders for the status of different tasks of the containment step.
- 2.3.4. Record and maintain all the information regarding steps taken for the containment efforts and notify the concerned internal stakeholders, where required.

2.4 REMEDIATING INCIDENTS

Remediation phase involves implementation of measures to prevent the incident from further propagating and preventing such future occurrences from happening. Coordination with all concerned stakeholders for an eradication strategy to ensure an effective and efficient removal of the threat(s).

For achieving the above, appropriate actions may be carried out by the relevant teams on the advice of IMT with defined timelines, including but not limited to

- 2.4.1. Scan systems and remove malicious software as needed.
- 2.4.2. Patch vulnerabilities and correct mis-configurations.
- 2.4.3. Wipe and re-install systems after appropriate post forensic clearance.
- 2.4.4. Monitor for previously unidentified and/or newly compromised resources
- 2.4.5. Assess previously implemented temporary containment measures
- 2.4.6. Remove the containment measures that are no longer valid or useful
- 2.4.7. Further refine temporary measures for effectiveness

Record and maintain all the information regarding steps taken for remediation and notify IMT and internal stakeholders where required.

2.5 RECOVERY

Recovery phase involves returning the systems/network to normal operation after thoroughly eradicating the threat/s of incident in the IT environment. This also involves revising the temporary response measures. Typically following actions are required in this phase by the relevant teams; there may be others depending on the nature of the incident.

- 2.5.1. Send notification to the appropriate parties and indicate that this event is in the Recovery and closure Phase
- 2.5.2. Restore data from backups.
- 2.5.3. Remove temporary firewall rules, router ACLs, or interim system modifications required for containment.
- 2.5.4. Reconnect systems to the network

Record and maintain all the information regarding steps taken for remediation and notify IMT and internal stakeholders where required.

2.6 FOLLOW-UP / LESSONS LEARNED

This is the final stage of the incident response life cycle. This phase involves conduct of meeting wherein root cause analysis and performance assessment of the incident response efforts is done by IMT ensuring implementation of any outstanding recommendations or

additional tasks to prevent future attacks and relevant ticket closure to indicate the “all clear” to resume normal scheduling and personnel resource allocation. IMT shall develop a formal incident report “Annexure A” for presenting to ITSC with the final outcome including actionable suggestions to modify existing policies, processes, and technologies to improve overall response capabilities in the future. Further to this, IMT shall identify the affected customer accounts, cards, etc and forward, after concurrence of Chief RMG, to Claim Settlement Committee to initiate process for compensation, if any. The Claim Settlement Committee shall adopt a process to ensure compliance with Regulatory timeline of compensation in 48 hours to the effected customers. Recommendation for handling reputation loss as per Reputational Risk Management Framework of the Bank shall also be made part of the final report.

Infosec shall submit MIS on incidents, logs, breaches etc. for regular review of the Senior Management and significant incidents shall be submitted for review to the IT Steering Committee on a regular basis.

DH-SOC Report on security breaches shall be regularly submitted to BoD, MANCO, Senior management and to the regulator as per regulatory requirement on prescribed reporting templates including quarterly statement on such incidents to Payment System Department of SBP on prescribed format (ANNEXURE B).

The Card Security Data Breach is already covered in the “Card Security Framework” and shall be reported as defined in that framework.

3. ROLES & RESPONSIBILITIES

3.1 USERS – EMPLOYEES

- 3.1.1 Adhere to the bank's information security policy and procedures.
- 3.1.2 Report incidents immediately when suspected/detected, to their line management as any delay in reporting the incident would cause loss of substantial evidence.

3.2 INCIDENT MANAGEMENT TEAM

- 3.2.1 Analyzing the event/incident and advise relevant teams to collect the relevant information
- 3.2.2 Identify respective containment measure
- 3.2.3 Consult SM, Principal vendor/s
- 3.2.4 Advise containment measures to the relevant teams
- 3.2.5 Advise remediation measures to the relevant teams
- 3.2.6 Carry out root cause analysis
- 3.2.7 Notify relevant Stakeholders with the progress in each step of the incident life cycle
- 3.2.8 Carry out performance assessment of the incident response efforts
- 3.2.9 Prepare the Incident Report and present to ITSC and other concerned forums
- 3.2.10 Provide support in legal proceedings to safe guard the bank's interest

3.3 SECURITY OPERATIONS CENTER

- 3.3.1 Coordinate with relevant departments to gather incident information.
- 3.3.2 Provide all relevant available log data and analytics to the IMT for incident investigation/analysis.
- 3.3.3 Implement new/modify monitoring rules as directed by the IMT and report any abnormalities.
- 3.3.4 Follow recommendations as advised by the IMT during different steps of incident management life cycle

3.4 ITG/ FRMR TEAMS

- 3.4.1 Provide all relevant available log data and analytics to the IMT for incident investigation/analysis.
- 3.4.2 Follow instructions as advised by the IMT during different steps of incident management life cycle.

3.5 DH-SOC

- 3.5.1 Provide all relevant available log data and analytics to the IMT for incident investigation / analysis.
- 3.5.2 Follow instructions as advised by the IMT during different steps of incident management life cycle.
- 3.5.3 Maintain incident report record and submit incident report to the all concerned

3.6 COMPLIANCE GROUP-CG

- 3.6.1 Ensure that the suggestions mentioned in the incident report are being complied.

4. INTERDEPENDENCIES

Sr. No.	Detail Description of Inter dependency	Section No.	Relevant Group(s)
1	Reporting of security breach events immediately upon a suspicion that this event may lead to some security incident	2	All Groups
2	Preliminary evaluation of the event & reporting to IMT	2	All Groups
3	Analyze event/incident to determine the risk exposure	2.2.1	ITG, DBG, SAMG
4	Make changes in identified Information technology components to contain the incident	2.3	ITG, DBG, SAMG
5	Make changes in identified Information technology components to eradicate the incident	2.4	ITG, DBG, SAMG
6	Returning the systems/network to normal operation after thoroughly eradicating the threat/s of incident in the IT environment	2.5	ITG, DBG, SAMG
7	Performing root cause analysis and a performance assessment of the incident response efforts	2.6	ITG, DBG, SAMG

5. PROCESS FLOW

5.1 Identification/Detection of Incident

Task Code	Task / Action	Responsibility/ Functional Title	Nature of Control (Compliance/Financial Reporting/Operational) Activity/Information	Type of Control (Automated/ Manual)	Reference of Regulatory Circular (In case of compliance control)
5.1.1	Reporting incident to the line manager	All employees	Operational	Manual	
5.1.2	Evaluating the event/incident and reporting to IMT	Line Management (DH/UH)	Operational	Manual	
5.1.3	Analyzing the event/incident and gathering related information	IMT(DH/UH)	Operational	Manual	
5.1.4	Recording the Findings about collection of information, IMT communication with the relevant teams	IMT(DH/UH)	Operational	Manual	
5.1.5	Notifying Relevant Stakeholders	IMT, CG	Operational & Compliance	Manual	BPRD Circular No. 05 dated May 30, 2017 PSD Circular No. 03 of 2015

5.2 Incident containment

Task Code	Task / Action	Responsibility/ Functional Title	Nature of Control (Compliance/Financial Reporting/Operational) Activity/Information	Type of Control (Automated/ Manual)	Reference of Regulatory Circular (In case of compliance control)
5.2.1	Identify respective containment measure	IMT(DH/UH)	Operational	Manual	

5.2.2	Consult SME, Principal vendor/s	IMT(DH/UH)	Operational	Manual	
5.2.3	Advise containment measures to the relevant teams	IMT(DH/UH)	Operational	Manual	
5.2.4	Implement the containment measure	Network/ SI & SDA / EAM	Operational	Manual	
5.2.4	Record all the information regarding steps taken for containment	Network/ SI & SDA / EAM	Operational	Manual	
5.2.5	Update Record for the incident stage	IMT(DH/UH)	Operational	Manual	
5.2.6	Notifying Relevant Stakeholders with the progress	IMT(DH/UH)	Operational	Manual	

5.3 Remediating the Incident

Task Code	Task / Action	Responsibility/ Functional Title	Nature of Control (Compliance/Financial Reporting/Operational) Activity/Information	Type of Control (Automated/ Manual)	Reference of Regulatory Circular (In case of compliance control)
5.3.1	Advise remediation measures to the relevant teams	IMT(DH/UH)	Operational	Manual	
5.3.2	implement measures to prevent the current incident from	Network/ SI & SDA / EAM/Vendor	Operational	Manual	

	further propagating				
5.3.3	Record all the information regarding steps taken for remediation	Network/ SI & SDA / EAM	Operational	Manual	
5.3.4	Notifying Relevant Stakeholders with the progress	IMT(DH/UH)	Operational	Manual	

5.4 Recovering from incident

Task Code	Task / Action	Responsibility/ Functional Title	Nature of Control (Compliance/Financial Reporting/Operational) Activity/Information	Type of Control (Automated/ Manual)	Reference of Regulatory Circular (In case of compliance control)
5.4.1	Make necessary arrangements for returning the systems/network to normal operations	Network/ SI & SDA / EAM/Vendor	Operational	Manual	
5.4.2	Record all the information regarding steps taken for Recovery phase	Network/ SI & SDA / EAM	Operational	Manual	
5.4.3	Notifying Relevant Stakeholders with the progress	IMT(DH/UH)	Operational	Manual	

5.5 Follow UP and Lesson learned

Task Code	Task / Action	Responsibility/ Functional Title	Nature of Control (Compliance/Financial Reporting/Operational) Activity/Information	Type of Control (Automated/Manual)	Reference of Regulatory Circular (In case of compliance control)
5.5.1	Carry out root cause analysis	IMT(DH/UH)	Operational	Manual	
5.5.2	Carry out performance assessment of the incident response efforts	IMT(DH/UH)	Operational	Manual	
5.5.3	Prepare the Incident Report and present to ITSC	IMT(DH/UH)	Operational	Manual	
5.5.4	Maintain Record of the incident report for review, sharing/submission and future reference	DH-SOC	Operational/Compliance	Manual	BPRD Circular No. 05 dated May 30, 2017

6. VERSION HISTORY

Revision Number	Updated by	Short Description of Revisions	Date
Version 1.0	IRU -RMG	First draft of procedure presented to the committee for approval.	March 29, 2016
Version 2.0	InfoSec - RMG		2019

Presented in RMC through Circulation
 Meeting No. 15 Dated: 15/10/2019
 Initial: 

7. ANNEXURES

7.1 ANNEXURE A –INCIDENT REPORT FORM

 Allied Bank Limited			
Reported Incident			
Ref #		Operator / Reporter Name	
Impact/nature of Incident			
Location		Problem Reporting Time & Date	
Problem Resolved Time & Date			
Problem Description			
I			
Steps taken for containment and remediation			
Root cause and measure taken to prevent the recurrence			
Group Head InfoSec & Gov.			

7.2 ANNEXURE B – REPORTING TEMPLATE AS PER PSD CIRCULAR NO. 03 OF 2015 (for reporting to SBP)

Details of Established Security Breaches in IB

Name of the bank: Allied Bank Limited

For the Quarter Ending: _____

Sr.	Source of security breach discovery	Nature of security breach	Reasons for the occurrence of security breach (e.g. Breach of controls, Procedures were not followed, weaknesses in implemented security controls etc.)	Impact of security breach (e.g. on banks business, systems, customers etc)	Action(s) taken to rectify the Security Breaches	Remarks (further details, if any)

Submitted By: _____

Designation & Seal: _____

Contact No: _____

7.3 ANNEXURE C – Information Security Posture


Information
Security Posture.pdf

Presented in RMC through Circulation
Meeting No. 15 Dated: 15/10/2019
Initial AK

8. GLOSSARY

8.1 ACRONYMS

ABL	Allied Bank Limited
ACL	Access Control List
CG	Compliance Group
DH	Divisional Head
FRMR	Fraud Risk Management & Regulatory Reporting
ITG	Information Technology Group
IMT	Incident Management Team
RMG	Risk Management Group
SMEs	Subject Matter Experts
SOC	Security Operation Center

8.2 DEFINITIONS

a. Event:

Anything that happens or takes place such as user actions, system occurrences of a particular set of circumstances.

b. Incident

Incident is an undesired event where business disruption reaches beyond the tolerance level of the organization. Any event that is either unpleasant or unusual.

c. Information Security

Safe-guarding an organization's data from unauthorized access or modification to ensure its availability, confidentiality, and integrity.

d. Information Security Event

A security event is any observable occurrence that is relevant to information security and may potentially have information security implications.

e. Information Security Incident

A security incident is a security event that results in damage or risk to information security assets and operations.

f. Internal Stakeholder

Internal stakeholders include, Management Committees, senior management, impacted managers, employees

g. Relevant Teams

This include different members of RMG, ITG, SAM & DBG Groups to whom task will be assigned by IMT for taking remedial actions.

h. Security Breach

Any incident that results in unauthorized access of systems, applications, data, services, networks and/or devices by bypassing their underlying security mechanisms.